T08 · MCP服务端实现与安全加固

> 课程：AI 智能体工程化项目实战 | 讲次：第 08 讲 | 学时：4 | 本讲分值：3.0 分 组别：_____ | 成员：_____ | 日期：_____

一、委托背景（企业原话）

> 客户有自己的 Agent
> 平台，不想重写界面，要求直接对接能力。三家子公司三套对接方式，维护成本已经失控。

二、任务目标

- 实现符合 MCP 2025-03-26 的服务端
- 正确划分 tools/resources/prompts 三类原语
- 配置白名单与 SSRF 防护

三、交付物清单

序号	文件	说明
1	`mcp_manifest.json`	3 tools + 2 resources + 1 prompt
2	`[redacted].md`	完整 JSON-RPC 报文（含 initialize）
3	`[redacted].md`	3 个 SSRF 载荷的测试结果

四、约束条件

- 资源 URI 必须做越权与路径穿越校验
- 未在白名单的工具不可调用
- 每次调用必须有审计记录（含 trace_id）

五、实施步骤

- 写 manifest（15 分钟）
- 实现 tools/list 与 tools/call（20 分钟）
- 实现 resources/read（含 URI 校验）（15 分钟）
- 实现 prompts/get（10 分钟）
- 用 curl 走通全链路并保存报文（15 分钟）
- 跑 3 个 SSRF 载荷并加固（20 分钟）

六、验收标准（DoD）

- [ ] manifest 三类原语齐全
- [ ] 非法 URI 被拒（越权/穿越）
- [ ] 未在白名单的工具不可调用
- [ ] 每次调用有审计记录
- [ ] 3 个 SSRF 载荷全部被拦

七、评分（本讲）

评分点	权重
协议实现	35%
原语边界	25%
安全防护	30%
文档质量	10%

八、提交要求

- 位置：小组仓库 `artifacts/T08_MCP■■■■■■■■■■/`
- 命名：`T08_MCP■■■■■■■■■■_■N■_v1`
- 截止：本讲课后 48 小时内（逾期 ×0.8，超过 1 周不计分）
- 必写：同目录 `README.md`（做了什么、怎么验证、遗留问题）

九、思考题

- REST 不够吗？
- 工具和资源有什么区别？
- 白名单够安全吗？